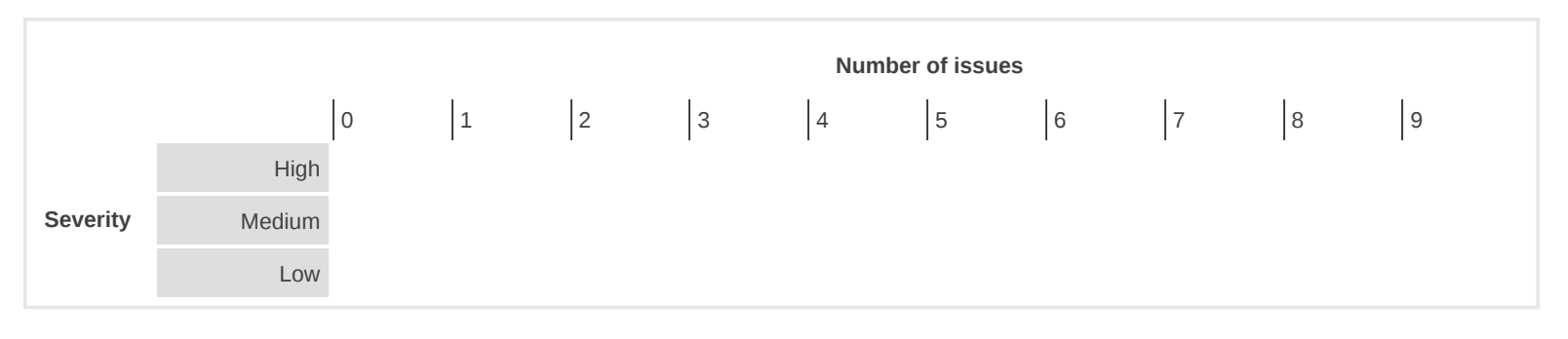
Burp Scanner Report

Summary

The table below shows the numbers of issues identified in different categories. Issues are classified according to severity as High, Medium, Low, Information or False Positive. This reflects the likely impact of each issue for a typical organization. Issues are also classified according to confidence as Certain, Firm or Tentative. This reflects the inherent reliability of the technique that was used to identify the issue.

		Confidence			
		Certain	Firm	Tentative	Total
Severity	High	0	0	0	0
	Medium	0	0	0	0
	Low	0	0	0	0
	Information	7	2	1	10
	False Positive	0	0	0	0

The chart below shows the aggregated numbers of issues identified in each category. Solid colored bars represent issues with a confidence level of Certain, and the bars fade as the confidence level falls.



Contents

1. Cross-site request forgery

2. User agent-dependent response

- 2.1. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
- 2.2. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/scripts/jsd/b0e4a89976ce/main.js

3. Cookie scoped to parent domain

- 3.1. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
- 3.2. https://www.atherenergy.com/robots.txt

4. Backup file

- 4.1. https://www.atherenergy.com/robots.jar
- 4.2. https://www.atherenergy.com/robots.txt.jar

5. Robots.txt file

6. Cacheable HTTPS response

- 6.1. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
- 6.2. https://www.atherenergy.com/robots.txt

1. Cross-site request forgery

Next

Summary

Severity:	**Information**
Confidence:	**Tentative**
Host:	**https://www.atherenergy.com**
Path:	**/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02**

Issue detail

The request appears to be vulnerable to cross-site request forgery (CSRF) attacks against unauthenticated functionality. This is unlikely to constitute a security vulnerability in its own right, however it may facilitate exploitation of other vulnerabilities affecting application users.

Issue background

Cross-site request forgery (CSRF) vulnerabilities may arise when applications rely solely on HTTP cookies to identify the user that has issued a particular request. Because browsers automatically add cookies to requests regardless of their origin, it may be possible for an attacker to create a malicious web site that forges a cross-domain request to the vulnerable application. For a request to be vulnerable to CSRF, the following conditions must hold:

- The request can be issued cross-domain, for example using an HTML form. If the request contains non-standard headers or body content, then it may only be issuable from a page that originated on the same domain.
- The application relies solely on HTTP cookies or Basic Authentication to identify the user that issued the request. If the application places session-related tokens elsewhere within the request, then it may not be vulnerable.
- The request performs some privileged action within the application, which modifies the application's state based on the identity of the issuing user.
- The attacker can determine all the parameters required to construct a request that performs the action. If the request contains any values that the attacker cannot determine or predict, then it is not vulnerable.

Issue remediation

The most effective way to protect against CSRF vulnerabilities is to include within relevant requests an additional token that is not transmitted in a cookie: for example, a parameter in a hidden form field. This additional token should contain sufficient entropy, and be generated using a cryptographic random number generator, such that it is not feasible for an attacker to determine or predict the value of any token that was issued to another user. The token should be associated with the user's session, and the application should validate that the correct token is received before performing any action resulting from the request.

An alternative approach, which may be easier to implement, is to validate that Host and Referer headers in relevant requests are both present and contain the same domain name. However, this approach is somewhat less robust: historically, quirks in browsers and plugins have often enabled attackers to forge cross-domain requests that manipulate these headers to bypass such defenses.

References

- Web Security Academy: Cross-site request forgery
- Using Burp to Test for Cross-Site Request Forgery
- The Deputies Are Still Confused

Vulnerability classifications

- CWE-352: Cross-Site Request Forgery (CSRF)
- CAPEC-62: Cross Site Request Forgery

Request

```
POST /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=co9n6jWv7JGbx4K_kclQE_YCZYu0VdR4r6ufJnIR.iE-1741073110-1.0.1.1-
rhKPtUtyqaTHkrcKVQmw11bYQhqj_t.vKL3s7fTb.zPTWbrAYGGgGo25JjZ0NOFXvV8qFOBohss7aWjPanJyC_JTGtHuJ3qS4uUpgzDNQ7U;
cf_clearance=Bio0Ng5EMsIbglUHIJqXFLyK8w779hapozdP.nSwDRI-1741073111-1.2.1.1-
tbyG8qj88heBqNhUAxxDW5uXrZuMQZR.rG9RBotYAeD3MdpcgEv8rctCjGpa2e_QzFfGs46BbKEFY9xbdU4tusc6jr7gz9336Zoy4zfxjyM.wD13Mn_VMCO_CgyKx
FOOcjeHG.TleL8byDKBeAj4uwRJaizOqJCGGeBSRfuSSngmiU3IO5xo36Oaz3Gf1of407MKvXpPnb_9NBiuSMPvGmfh12DMiqab_K2fKnYpwIssY.xIruDmykaiq.xi1
s7bBWt.w_G0J8RgETy0otXBDSGs4JGA5PSFMr84ad9Q2pPSZW5kf7SMSGmsANylymxjCalwU_0HVtOF9RI6bkdcanGlscy5Nbn_YjJ9BWsZlth9c4RwL7QUFuC
Ar6sRF3G94T_FIKV1OBEHYd.WadDN7fLxoyzZ9Zx2FquC2ctCrJI
Origin: https://www.atherenergy.com
Content-Type: text/plain;charset=UTF-8
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
```

Response

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:25:11 GMT
Content-Type: text/plain; charset=UTF-8
Content-Length: 0
Set-Cookie: cf_clearance=; Path=/; Expires=Thu, 01-Jan-70 00:00:00 GMT; Domain=atherenergy.com; HttpOnly; Secure; SameSite=None
Set-Cookie: cf_clearance=mtIZN7xAqxqQVvZexR_IBU.MZPnv54CJXw366s_y.WA-1741073111-1.2.1.1-
VVZrvquLaVTzw_z9zS011E15TM4t6oYMJZ3KbHaDCUa_rAAZ9l54pLTG3FlpNWD.5WvR1hScgwkBp0CSixrTAtXJq9SaJvwlmrHCRhHfJiBn.HnTKkUA30KY064
My1KxlQ7fNmrk95Fqask5GXkBobvTn4EdUQKnkUKRg.kwosPH7DigMwN5cpCeUREgODBpaO6xWolxcfsoYQizyWRpd7ZUKS5Z6BqgveqQSsO4AxotqRiIkhMZy
HJUb45Ywzrm.Opd97Bg56iyMP.HSy0om_Bt5NDm.BZ7IoN8ZgcDpFZXh9ShE8OHOTZXP4TPn8ypQC4rce0V8xpONWl3aRGjYIIfkljlf4F_rMEtUWql26EMERTcN
Oo_1ffUC9w_8gr1oC4kbab.FPWUKIzmWZoN3zZoc.VdJBMC9473HZvaLCY; Path=/; Expires=Wed, 04-Mar-26 07:25:11 GMT; Domain=atherenergy.com;
HttpOnly; Secure; SameSite=None; Partitioned
Server: cloudflare
Cf-Ray: 91afa3654a78ef02-AMS
Alt-Svc: h3=":443"; ma=86400
```

2. User agent-dependent response

Previous Next

There are 2 instances of this issue:

- /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
- /cdn-cgi/challenge-platform/h/b/scripts/jsd/b0e4a89976ce/main.js

Issue description

Application responses may depend systematically on the value of the User-Agent header in requests. This behavior does not itself constitute a security vulnerability, but may point towards additional attack surface within the application, which may contain vulnerabilities.

This behavior often arises because applications provide different user interfaces for desktop and mobile users. Mobile interfaces have often been less thoroughly tested for vulnerabilities such as cross-site scripting, and often have simpler authentication and session handling mechanisms that may contain problems that are not present in the full interface.

To review the interface provided by the alternate User-Agent header, you can configure a match/replace rule in Burp Proxy to modify the User-Agent header in all requests, and then browse the application in the normal way using your normal browser.

Vulnerability classifications

- CWE-16: Configuration

2.1. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02

Next

Summary

Severity:	**Information**
Confidence:	**Firm**
Host:	**https://www.atherenergy.com**
Path:	**/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02**

Request 1

```
POST /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=Rehdp.XRn6UPhnZijnByNlfj5cUc0MJVv_.3qJwJ4Pk-1741075333-1.0.1.1-
eDit1awlBTjnapMMvo53FPewDt7.JvP51elgUyVRfU7jz7qfDkqqCXK71XNmSTto7tZgt_jDkG6r_FD5GmnckREOoyJwClHJ9MjdH8ae3fA;
cf_clearance=EWYYRYuK4o5x_CPAhX0Np5DhqvVdAIDFegBXprM7TbM-1741075334-1.2.1.1-
vr_sJmWSHza.vrAbPCWO7_sZ8daETpV3OB596lcJLgOITOT_ig1iKyTAk1tlt5terIm3x348AuwbNJoS6fAKZr4a39O5VkaBmYpsNR0wvpE9h6NgIbUSBVH.wSn2l.
Gr3ZXl37g8nq15_XcxY7YHT_jI6vOTRCkieEsQDnOEu5mpJJsj4EsRuaroQoKI5aDp7tPT1UJ2vZO9MJSZSzjcX.0s6vjUbNhYOCsXJqJHhrcKf98AVYV2lE6xo4tiB
MiYth7go7rZyLi6aXlOODzRS4CvIGEn3NxOi3tq4amhmou5HP.Cb_fGu2WTcFXG9gz0B._lJuWC2HO4sd_Z.24noZjO3nNIwxW_KNkGgLAPHJ_RcWnllq04VxJC6d
lEz.UdOvS.99DBHAMyWxvHFpkuZshGgnZxg86smDcCFvY3_wA
Origin: https://www.atherenergy.com
Content-Type: text/plain;charset=UTF-8
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 08:02:15 GMT
Content-Type: text/plain; charset=UTF-8
Content-Length: 0
Set-Cookie: cf_clearance=; Path=/; Expires=Thu, 01-Jan-70 00:00:00 GMT; Domain=atherenergy.com; HttpOnly; Secure; SameSite=None
Set-Cookie: cf_clearance=7YVLzk6plGwThiOrgv3mEeW1JL_4U5C4QPVZ7ZoyTrI-1741075335-1.2.1.1-
8T1Grl2mAUUk6XcVLHJ9VXZBa8MxUBkaOkQxAmwPfVJVg2KOAuylnqmSmciVPhtxJterZmztlITkfbnUloBbMZs05SloHi0Xt3GNVnyZrWGCBlQrijIFjyMd1ffmjOaa
I087qhfPtYRTHL5.j6qzWpPsB3jQAM60zAbU95NsU0lcYRK9gBrPypfAvkb2qsVEutNyf6lPnlSrgC1cgiV2Q6lAIWwClZ8eBajDuawsBVCeWSfFVM4vvw.tPn2WMSK
3il4pbk96EulnQac_9N1B25gxyZ3mDly4MNvSZLZEXzOZltHI368AVvJb0kt_JPpm3XZaq1uub2nHWUtKjqN4zd_hQZJfdri3hTOpRPyEJrkEvu7y.Kl5mZBZryYJwS7j
yL0xZC7cdRQmIUEthHf7aiNqAEupadd4dtywcwihxBU; Path=/; Expires=Wed, 04-Mar-26 08:02:15 GMT; Domain=atherenergy.com; HttpOnly; Secure;
SameSite=None; Partitioned
Server: cloudflare
Cf-Ray: 91afd9ad5d151ca4-AMS
Alt-Svc: h3=":443"; ma=86400
```

Request 2

```
POST /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (iPhone; CPU iPhone OS 5_1 like Mac OS X) AppleWebKit/534.46 (KHTML, like Gecko) Version/5.1 Mobile/9B176 Safari/7534.48.3
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=8NoB_EytERkcmWxuJQUl7llhWw5Cztf103UG3G0xQhI-1741075336-1.0.1.1-
cbFhJAPO.VBf2pbw92_nMCbvXp2exJ3Dgk3LYUBIZJ6H7XYEL19WRek0ydKUkmTOR06gMr3FiBsXpyuep.w.qICE4GGLS.Luj4kV03Oj6dY;
cf_clearance=le0wPuV8SsePsnxiCm9WTd_QpXskynj9ypFBKKjeLyk-1741075336-1.2.1.1-
aFXYXw5sbz3ucvazEPdDvr5QuXufU2voU2zWvjBJaxp59l6Vw590go_WWOrfnD.aeeS31Ojz3XkCoo4APpHXlkfqAHagTAi5tWbuOodStHEjgf49e..JVJo8VmqXoc8
OndTCeMNtLXk1WtoSMg.gh3m4Di7sd_1fkBuyUsq578Hjg0cEorZVYdz.nmA27ugk_26fL9NDVX1vWszCv3G1HYgH4V0L9v9CQ9HlnB5OpPF0yUs13te42rvwGO
yqFV.c94p9Pn.XW4ZdZA7xLYfyIOjES8TF1jbPZv_vSezLSeEG9Gsq2lR65TEJ5czApulpARkLhzVaIfQQLjmGcNjWAz8hhkIYTpU92Tm6BCbbe_ub2qE.J02xDYx0S
rCBnKeEnmOL1J0G6MfBM_L4WeFvJz8tXrg4UJCYk.2rwtgNCeI
Origin: https://www.atherenergy.com
Content-Type: text/plain;charset=UTF-8
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
```

Response 2

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 08:02:17 GMT
Content-Type: text/plain; charset=UTF-8
Content-Length: 0
Set-Cookie: cf_clearance=; Path=/; Expires=Thu, 01-Jan-70 00:00:00 GMT; Domain=atherenergy.com; HttpOnly; Secure; SameSite=None
Set-Cookie: cf_clearance=YQKASn361YmCWr44_5yJsf1kICRK5X19HH8wdgJYr0U-1741075337-1.2.1.1-
JbemoV0lZaHGYcnSteHLFW1dUpO7PMv53HRV6qbm7RhU4aXZQtS5L3.G2eELX0QfQ0Yhs6.1JyrYiVluc8Q1QbuFX9dDS.kxuOGtLUSgx86Uo0ZoiAyIFU0fv03
PLnjtiCkOSrU8UnvZEp9GuwMvDw76z47jPj.ks3LjZjL2tNRffJQWj3.ta7W26oCFOItnwpzhVpmE.dSSfBR8lvhZ2OYHaNNzVyU.lIDhNPsLmRMVoTMh9zKU_gE4.t4
DpT5leB4En6mygnrsEhx.nzwhGLGhP_kvCHL1xdWsT1Hbf7DS1Llg2c284.FQSGL1wq46EZxMIhV_ax0pn4Zup7Cahq1wA0_cyEP8kQ1XK1sU.IPXsyOz5j3O5w8
YEMSkc61goDk9bv4ndVtv9Ca.hi_NA_zDs3hvIhVls6_OGxFNiNI; Path=/; Expires=Wed, 04-Mar-26 08:02:17 GMT; Domain=atherenergy.com; HttpOnly; Secure;
SameSite=None; Partitioned
Set-Cookie: __cf_bm=Vq2dHmpjTlaDGM6Gq9SdVZMB3u2jveSwClwm0KKeIho-1741075337-1.0.1.1-
76jpRby76DR4kDqlywcF7hy1hmm4SD8TIxhnLbMwesmtPlZ9guxtDc9WKB5vHsLN_nLo6HDXqqReALiHkzISRiVkUR5NjxauTKNCBYjsL5Y; path=/; expires=Tue,
04-Mar-25 08:32:17 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afd9bc083c1ca4-AMS
Alt-Svc: h3=":443"; ma=86400
```

2.2. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/scripts/jsd/b0e4a89976ce/main.js

Previous Next

Summary

Severity:	**Information**
Confidence:	**Firm**
Host:	**https://www.atherenergy.com**
Path:	**/cdn-cgi/challenge-platform/h/b/scripts/jsd/b0e4a89976ce/main.js**

Request 1

```
GET /cdn-cgi/challenge-platform/h/b/scripts/jsd/b0e4a89976ce/main.js? HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=vHrlw3X87QqVju4o9ytrzvjHkmXT2Fmlnqnfo96Sepc-1741075101-
1.0.1.1-.l5Q4rF4f9lcXRmuhtduiGm.vri2p6O1y3zZshE42LsDdpD8VpJbzDKDPSVyrc96JDkZO7zKsdmLjbxh_smn9vWugM5NBQ8DjNO7MyX2hFc;
cf_clearance=P7lFCZfPb7Atn6BxFp7AFEhtoSVxPca8wGVO91eYGGk-1741075105-1.2.1.1-
BhB.uzfUDihqUyhCbhRmm8lco49vSrCwbsL7uRkoEZQhDdKW3dT8Q02fnirj0EgWfwn4Sijwq9aabwrP6ehG6lwlpMrae9lI4VoMVlLEhVecAuhsk2XUvZlM5D7ksKh
s2yzVG90wp2P232pxPllBr4uWiGTtZWCrZFmfobipVwOfAy2Fbkaa1qjcYp4sBlQP2IM8bY5AEKhzqmJ88HAxePZbQgF_YoQ2PCGh97ZcBAzya8EpXun4v4Yddvd
ux2xUnWvLGnTJuJaFyPoLMtkPIyw6EJbQ7_SEgElgq4wkqtNSPOVfs.jS8v_B4DQkSQ02SlwIuUnQlB41SafVHZPBQzTOwgLfTHmTfBwOurYYWI.tg2nD52dwhL.
YcLupDxXlUaXRqQyzC4hJekDW8fBuZbAGm4XfNQDlTct_AnIX_sI
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
Sec-CH-UA-Mobile: ?0
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:58:25 GMT
Content-Type: application/javascript; charset=UTF-8
Cache-Control: max-age=14400, stale-if-error=10800, stale-while-revalidate=10800, public
X-Content-Type-Options: nosniff
Vary: Accept-Encoding
Server: cloudflare
Cf-Ray: 91afd413facc1ca4-AMS
Alt-Svc: h3=":443"; ma=86400

window._cf_chl_opt={cFPWv:'b'};~function(W,h,i,n,o,s,z,A){W=b,function(c,d,V,e,f){for(V=b,e=c();!!
[];)try{if(f=parseInt(V(373))/1+parseInt(V(329))/2+parseInt(V(364))/3*(-parseInt(V(317))/4)+parseInt(V(403))/5+-parseInt(V(313))/6+parseInt(V(328))/7*
(parseInt(V(305))/8)+-parseInt(V(394))/9,f===d)break;else e.push(e.shift())}catch(E){e.push(e.shift())}}(a,588734),h=this||self,i=h[W(309)],n=function(a4,d,e,f)
{return a4=W,d=String[a4(368)],e={'h':function(E){return E==null?'':e.g(E,6,function(F,a5){return a5=b,a5(397)[a5(308)]
(F)})},'g':function(E,F,G,a6,H,I,J,K,L,M,N,O,P,Q,R,S,T,U){if(a6=a4,null==E)return'';for(I={},J={},K='',L=2,M=3,N=2,O=
[],P=0,Q=0,R=0;R<E[a6(387)];R+=1)if(S=E[a6(308)](R),Object[a6(374)][a6(325)][a6(301)](I,S)||(I[S]=M++,J[S]=!0),T=K+S,Object[a6(374)][a6(325)][a6(301)]
(I,T))K=T;else{if(Object[a6(374)][a6(325)][a6(301)](J,K)){if(256>K[a6(402)](0)){for(H=0;H<N;P<<=1,Q==F-1?(Q=0,O[a6(404)]
(G(P)),P=0):Q++,H++);for(U=K[a6(402)](0),H=0;8>H;P=P<<1.29|1.33&U,F-1==Q?(Q=0,O[a6(404)]
(G(P)),P=0):Q++,U>>=1,H++);}else{for(U=1,H=0;H<N;P=U|P<<1,F-1==Q?(Q=0,O[a6(404)](G(P)),P=0):Q++,U=0,H++);for(U=K[a6(402)]
(0),H=0;16>H;P=P<<1.83|U&1,F-1==Q?(Q=0,O[a6(404)](G(P)),P=0):Q++,U>>=1,H++);}L--,L==0&&(L=Math[a6(395)](2,N),N++),delete J[K]}else
```

Request 2

```
GET /cdn-cgi/challenge-platform/h/b/scripts/jsd/b0e4a89976ce/main.js? HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (iPhone; CPU iPhone OS 5_1 like Mac OS X) AppleWebKit/534.46 (KHTML, like Gecko) Version/5.1 Mobile/9B176 Safari/7534.48.3
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=8x6X6wmeHotYog0V4cpy3DEJXIfXjPGo.2tZ1wstUD0-1741075107-1.0.1.1-
0FA1aJBs_MPVUlV2upHQ5Q23I5dJxgXZb08lmvYHLr.9x7pnCBYhYjrhi9gkkktqpR1OGVH468Qz4YRtwZG4qkrmztk6iN0wvyC1ZjSro8;
cf_clearance=8YSRxqwl1FHOPd8.Ab83zFwSXtK.3ZxH5rzZ290rEmM-1741075107-1.2.1.1-
Wxtqi.Chh1ZcrZmilhMoZMqO3651jr1FUhuWohbNTy1uWR8hd0Qz.79eptO3xyiqQDPa7F8kHa602Z.Us7ZSzBhkrtVEJFlIy7oZZMi9CcKge9CVaVu_5rKvNR5Qhdjb
92u79ZrgFALku1r8yhB791EYgepzw32wlqtemZSmHXYxsl5Nh82wIdk5pjbYSCC2D78mvPcBlg8hpMHzGp356DzgdlYNLPGD82k3H2W0t7zbgM1qN0PUhHTfdTY
JMSyvr3kx5.eu0czlYUhjBBwQ_IG_QvT6YWvtMX7S1HrTreDRs_CvrSiJn8iFa_LOPhgzCbO2E5G0LLCjEeQeWL0kiR_u2AvbX93WfSv208cEvWP92jugmTNWhta
xB75JaDnf7.7f7VxdAo_7NqGFew21IHqTtJVHaDVkOyqowrBL07o
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
Sec-CH-UA-Mobile: ?0
```

Response 2

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:58:28 GMT
Content-Type: application/javascript; charset=UTF-8
Cache-Control: max-age=14400, stale-if-error=10800, stale-while-revalidate=10800, public
X-Content-Type-Options: nosniff
Set-Cookie: __cf_bm=xXTlZ3Eofd3RMQKSuHujiHCDmwZhxV4WowThzm46ZTE-1741075108-1.0.1.1-
u9Xygv.UJGVvHJsASKJfEQ1dznjuIULvOCbCC0eh9VLs6VasKrbwP2rf7m0WtkNVUpm2l9_RhhwJt9VlnVytNHf.H_s7uSMxGvqNzkDCE1I; path=/; expires=Tue,
04-Mar-25 08:28:28 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Vary: Accept-Encoding
Server: cloudflare
Cf-Ray: 91afd423ee2f1ca4-AMS
Alt-Svc: h3=":443"; ma=86400

window._cf_chl_opt={cFPWv:'b'};~function(W,h,i,n,o,y,z,B){W=b,function(c,d,V,e,f){for(V=b,e=c();!![];)try{if(f=parseInt(V(256))/1+-parseInt(V(352))/2*
(parseInt(V(308))/3)+parseInt(V(312))/4+-parseInt(V(245))/5*(-parseInt(V(317))/6)+parseInt(V(274))/7+parseInt(V(276))/8*(-parseInt(V(338))/9)+-
parseInt(V(275))/10,f===d)break;else e.push(e.shift())}catch(E){e.push(e.shift())}}(a,659273),h=this||self,i=h[W(286)],n=
{},n[W(295)]='o',n[W(347)]='s',n[W(334)]='u',n[W(283)]='z',n[W(300)]='n',n[W(348)]='I',n[W(351)]='b',o=n,h[W(288)]=function(E,F,G,H,a8,J,K,L,M,N,O)
{if(a8=W,null===F||void 0===F)return H;for(J=x(F),E[a8(301)][a8(252)]&&(J=J[a8(349)](E[a8(301)][a8(252)](F))),J=E[a8(341)][a8(257)]&&E[a8(250)]?E[a8(341)]
[a8(257)](new E[(a8(250))](J)):function(P,a9,Q){for(a9=a8,P[a9(285)](),Q=0;Q<P[a9(244)];P[Q+1]===P[Q]?P[a9(320)](Q+1,1):Q+=1);return P}
(J),K='nAsAaAb'.split('A'),K=K[a8(262)][a8(293)](K),L=0;L<J[a8(244)];M=J[L],N=v(E,F,M),K(N)?(O=N==='s'&&!E[a8(280)](F[M]),a8(284)===G+M?
```

3. Cookie scoped to parent domain

Previous Next

There are 2 instances of this issue:

- /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
- /robots.txt

Issue background

A cookie's domain attribute determines which domains can access the cookie. Browsers will automatically submit the cookie in requests to in-scope domains, and those domains will also be able to access the cookie via JavaScript. If a cookie is scoped to a parent domain, then that cookie will be accessible by the parent domain and also by any other subdomains of the parent domain. If the cookie contains sensitive data (such as a session token) then this data may be accessible by less trusted or less secure applications residing at those domains, leading to a security compromise.

Issue remediation

By default, cookies are scoped to the issuing domain, and on IE/Edge to subdomains. If you remove the explicit domain attribute from your Set-cookie directive, then the cookie will have this default scope, which is safe and appropriate in most situations. If you particularly need a cookie to be accessible by a parent domain, then you should thoroughly review the security of the applications residing on that domain and its subdomains, and confirm that you are willing to trust the people and systems that support those applications.

Vulnerability classifications

- CWE-16: Configuration

3.1. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02

Previous Next

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02**

Issue detail

The following cookie was issued by the application and is scoped to a parent of the issuing domain:

- cf_clearance

The cookie does not appear to contain a session token, which may reduce the risk associated with this issue. You should review the contents of the cookie to determine its function.

Request 1

```
POST /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=vDHQje3WaDMIy8v6hQTWVkgn6h3P.pIZMRogn6tmvwk-1741073090-1.0.1.1-
p2k0.h7_89_xAFMq26gTrhC6tqHzf.i5jLRTg6UMs6TwUcW8GFriaTsrcitTP7jCj89TgK6xWVF7CBPOjaKk4U_PActv3oE_jI8s_DCuaug
Origin: https://www.atherenergy.com
Content-Type: text/plain;charset=UTF-8
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
Sec-CH-UA-Mobile: ?0
Content-Length: 15921

WHo5eB+meVoeEw8+C+ZP15BGPuMPfyfggBm+dkPsQGnQOoPxsiv8QV+KPECoXcHHPu-gPFPgGgo+Pbg+q8h5-VHY045sQlHMu3KZwXS5qleJMT+3ks-
fPeooRfxBYcPDXcOUYPU5wxPBJoPf5BB5lE5fP+QP1VAP+TYPLjmuXHi+u-
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:24:51 GMT
Content-Type: text/plain; charset=UTF-8
Content-Length: 0
Set-Cookie: cf_clearance=; Path=/; Expires=Thu, 01-Jan-70 00:00:00 GMT; Domain=atherenergy.com; HttpOnly; Secure; SameSite=None
Set-Cookie: cf_clearance=o4fulW2VqtADEbUAS3CdWYXX2xnd5wo804.cQTygE94-1741073091-1.2.1.1-
orswPdvPQ1579J6i3TV2MRAj60NIlcDUTFneX5BT1gOj8lx0i8CKR8n4cmLJkEgJE48FAv9_xDOs9MokcUJafEJjfr.emmjgTSUrQa0eNkA7rhWqnHtAa8qKKEXWkd
5_yCjlunfMpGp4glNUeX9uCwfLEH5TvhlNxn102qvHAe1B1KrV1eL8nnSp32XXP2g211dbY1iO.dLm5jUMi8wsglpWd5BNVnTHLzR4lN2HOAwHDc3hElFuGGcdBo
N.uPXz8dDWGwA8UmOwb.NKxRiZWVepoFoovGNwCejh6FQtlcths18ax8HYhl1zPe7CpmLMJrrgOP0gzzAiSMccz8.nV0Bhaj9QzjOk_HyU.Q0Fp5fcTHy.E_rhqbfO
ZxBIC_teLQraT7nwTSA.1k5wxCZ9.XzkQfBo8kw3f7KBQfALNtE; Path=/; Expires=Wed, 04-Mar-26 07:24:51 GMT; Domain=atherenergy.com; HttpOnly; Secure;
SameSite=None; Partitioned
Server: cloudflare
Cf-Ray: 91afa2e43f64ef02-AMS
Alt-Svc: h3=":443"; ma=86400
```

3.2. https://www.atherenergy.com/robots.txt

Previous Next

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/robots.txt**

Issue detail

The following cookie was issued by the application and is scoped to a parent of the issuing domain:

- __cf_bm

The cookie does not appear to contain a session token, which may reduce the risk associated with this issue. You should review the contents of the cookie to determine its function.

Request 1

```
GET /robots.txt HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:24:54 GMT
Content-Type: text/plain; charset=UTF-8
Cache-Control: public, max-age=10800
Last-Modified: Fri, 14 Feb 2025 16:03:45 GMT
Etag: W/"48-1950533a2e8"
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: MISS
Expires: Tue, 04 Mar 2025 10:24:54 GMT
Set-Cookie: __cf_bm=r559CTcjrzuzHAOjnffU1MpF625Gsqvhv6YTYFiO7Z8-1741073094-1.0.1.1-
HEW7pzEv2nfkx1ThN1BoHGs1Xx.ofcd5Qj4V1sg9HU9C5j4Q6SN1sZMgY2fV4rNqBwWn377yPjg2Y9Kkaw6y6aSBDFzMGhxcVsEfrZivhB4; path=/; expires=Tue,
04-Mar-25 07:54:54 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afa2f8ed74ef02-AMS
Alt-Svc: h3=":443"; ma=86400

User-Agent: *
Allow: /
```

4. Backup file

Previous Next

There are 2 instances of this issue:

- /robots.jar
- /robots.txt.jar

Issue description

Publicly accessible backups and outdated copies of files can provide attackers with extra attack surface. Depending on the server configuration and file type, they may also expose source code, configuration details, and other information intended to remain secret.

Issue remediation

Review the file to identify whether it's intended to be publicly accessible, and remove it from the server's web root if it isn't. It may also be worth auditing the server contents to find other outdated files, and taking measures to prevent the problem from reoccurring.

References

- Web Security Academy: Information disclosure via backup files

Vulnerability classifications

- CWE-530: Exposure of Backup File to an Unauthorized Control Sphere
- CAPEC-37: Retrieve Embedded Sensitive Data
- CAPEC-204: Lifting Sensitive Data Embedded in Cache

4.1. https://www.atherenergy.com/robots.jar

Previous Next

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/robots.txt**

Request 1

```
GET /robots.jar HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:31:32 GMT
Content-Type: text/html; charset=utf-8
X-Nextjs-Cache: MISS
X-Nextjs-Prerender: 1
X-Powered-By: Next.js
Cache-Control: public, max-age=10800
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: HIT
Age: 15
Expires: Tue, 04 Mar 2025 10:31:32 GMT
Set-Cookie: __cf_bm=VsE_CmQFzg13QlY7cJWDrZVTWx9t39Pu1zqfDnWF4ic-1741073492-1.0.1.1-
M.gVJkgQyjcrrg0lgsrRrhFfRqU7IlgA7793NKzIcuIqLR00vEnBxvtz9T7hhI5wDgG5DWEqKE_rciO1z7XywCNhgDgivc5LueQnCK8CkW8; path=/; expires=Tue, 04-
Mar-25 08:01:32 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afacb24f24ef02-AMS
Alt-Svc: h3=":443"; ma=86400

<!DOCTYPE html><html lang="en-US"><head><meta charSet="utf-8" data-next-head=""/><link rel="preconnect" href="https://media.atherenergy.com/" data-
```

Request 2

```
GET /lrgh.txt HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 2

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:31:35 GMT
Content-Type: text/html; charset=utf-8
X-Nextjs-Cache: MISS
X-Nextjs-Prerender: 1
X-Powered-By: Next.js
Cache-Control: s-maxage=28800, stale-while-revalidate=31507200
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: DYNAMIC
Set-Cookie: __cf_bm=kRdKu6ozsM5hMWioVkL0PwKnRB4j4NoIAyvhKsCdEg0-1741073495-1.0.1.1-
L_.Lr9.R5yKPs10rkh.SGp6O3iCwAfxKy9IxauO.rZ0DRJURd5nomWeAYh7YNx4KL1hAk_Ns7JntAFFTzaaxgOc90_kQQztYmH634DUOWQ8; path=/;
expires=Tue, 04-Mar-25 08:01:35 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afacc0cdb6ef02-AMS
Alt-Svc: h3=":443"; ma=86400

<!DOCTYPE html><html lang="en-US"><head><meta charSet="utf-8" data-next-head=""/><link rel="preconnect" href="https://media.atherenergy.com/" data-
next-head=""/><link rel="dns-prefetch" href="https://media.atherenergy.com/" data-next-head=""/><link rel="preload" href="/fonts/neurial-grotesk-regular.woff"
as="font" type="font/woff" crossorigin="anonymous" data-next-head=""/><link rel="preload" href="/fonts/neurial-grotesk-light.woff" as="font" type="font/woff"
```

4.2. https://www.atherenergy.com/robots.txt.jar

Previous Next

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/robots.txt**

Request 1

```
GET /robots.txt.jar HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:31:22 GMT
Content-Type: text/html; charset=utf-8
X-Nextjs-Cache: MISS
X-Nextjs-Prerender: 1
X-Powered-By: Next.js
Cache-Control: public, max-age=10800
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: HIT
Age: 16
Expires: Tue, 04 Mar 2025 10:31:22 GMT
Set-Cookie: __cf_bm=U9gEnyVLHOb24ItYkv9cGsTJs4IBTsSAtIdwyhTXOZw-1741073482-1.0.1.1-
XczmaJ.JUhHdCwWWhRZK.3BxCWH9jPMiHLmZA6tQLbqnLvWBCI0QztokoTqIfd6Sf7Vl3KsW4aKbybvcd1YMeKdkrkY28STbeaausIviJj4; path=/; expires=Tue,
04-Mar-25 08:01:22 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afac747ceaef02-AMS
Alt-Svc: h3=":443"; ma=86400

<!DOCTYPE html><html lang="en-US"><head><meta charSet="utf-8" data-next-head=""/><link rel="preconnect" href="https://media.atherenergy.com/" data-
```

Request 2

```
GET /uzxq.txt.jar HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 2

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:31:26 GMT
Content-Type: text/html; charset=utf-8
X-Nextjs-Cache: MISS
X-Nextjs-Prerender: 1
X-Powered-By: Next.js
Cache-Control: public, max-age=10800
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: MISS
Expires: Tue, 04 Mar 2025 10:31:26 GMT
Set-Cookie: __cf_bm=NV.ihECOB5IBMscp4ddI4HLm6PxgpVVC.utM_op3iy0-1741073486-1.0.1.1-
0fNmeq_icw3T6lGV76EKav1kM.ul6PoVt1KFAAXamj8VYd4Sdvfi1.ebCpWb3j8.d91N5d0wFM2KDb7o_tLo8NikfvrvGr3Ux7vTNZqafnA; path=/; expires=Tue, 04-
Mar-25 08:01:26 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afac870ea7ef02-AMS
Alt-Svc: h3=":443"; ma=86400

<!DOCTYPE html><html lang="en-US"><head><meta charSet="utf-8" data-next-head=""/><link rel="preconnect" href="https://media.atherenergy.com/" data-
next-head=""/><link rel="dns-prefetch" href="https://media.atherenergy.com/" data-next-head=""/><link rel="preload" href="/fonts/neurial-grotesk-regular.woff"
```

5. Robots.txt file

Previous Next

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/robots.txt**

Issue detail

The web server contains a robots.txt file.

Issue background

The file robots.txt is used to give instructions to web robots, such as search engine crawlers, about locations within the web site that robots are allowed, or not allowed, to crawl and index.

The presence of the robots.txt does not in itself present any kind of security vulnerability. However, it is often used to identify restricted or private areas of a site's contents. The information in the file may therefore help an attacker to map out the site's contents, especially if some of the locations identified are not linked from elsewhere in the site. If the application relies on robots.txt to protect access to these areas, and does not enforce proper access control over them, then this presents a serious vulnerability.

Issue remediation

The robots.txt file is not itself a security threat, and its correct use can represent good practice for non-security reasons. You should not assume that all web robots will honor the file's instructions. Rather, assume that attackers will pay close attention to any locations identified in the file. Do not rely on robots.txt to provide any kind of protection over unauthorized access.

Vulnerability classifications

- CWE-200: Information Exposure

Request 1

```
GET /robots.txt HTTP/1.1
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 1

```
HTTP/1.1 200 OK
Date: Tue, 04 Mar 2025 07:25:04 GMT
Content-Type: text/plain; charset=UTF-8
Connection: close
Cache-Control: public, max-age=10800
last-modified: Fri, 14 Feb 2025 16:03:45 GMT
etag: W/"48-1950533a2e8"
vary: Accept-Encoding
strict-transport-security: max-age=31536000; includeSubDomains
CF-Cache-Status: MISS
Expires: Tue, 04 Mar 2025 10:25:04 GMT
Set-Cookie: __cf_bm=CveTNNsMJg6jSS_BQZ3qq0rxW34s3FoQmzBO6c9wLFE-1741073104-1.0.1.1-
xreedaGeBnlf.9OSKs09SbiEIadaiHxj2wK280yWVGahtg9hfOsfE0klybjM1ONBl1d3YHKphNxIlucbgVcGgmCkifyHiUyNT.HmBfIAqYQ; path=/; expires=Tue, 04-
Mar-25 07:55:04 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
CF-RAY: 91afa333b91a4f9d-AMS
alt-svc: h3=":443"; ma=86400
Content-Length: 72

User-Agent: *
```

6. Cacheable HTTPS response

Previous

There are 2 instances of this issue:

- /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
- /robots.txt

Issue description

Unless directed otherwise, browsers may store a local cached copy of content received from web servers. Some browsers, including Internet Explorer, cache content accessed via HTTPS. If sensitive information in application responses is stored in the local cache, then this may be retrieved by other users who have access to the same computer at a future time.

Issue remediation

Applications should return caching directives instructing browsers not to store local copies of any sensitive data. Often, this can be achieved by configuring the web server to prevent caching for relevant paths within the web root. Alternatively, most web development platforms allow you to control the server's caching directives from within individual scripts. Ideally, the web server should return the following HTTP headers in all responses containing sensitive content:

- Cache-control: no-store
- Pragma: no-cache

References

- Web Security Academy: Information disclosure

Vulnerability classifications

- CWE-524: Information Exposure Through Caching
- CWE-525: Information Exposure Through Browser Caching
- CAPEC-37: Retrieve Embedded Sensitive Data

6.1. https://www.atherenergy.com/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02

Previous Next

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02**

Request 1

```
POST /cdn-cgi/challenge-platform/h/b/jsd/r/0.9755360933278836:1741069469:4q31qvkIFOX6XTpiTt1jwdDmIWqm8vgp8hSgxxWy2Y8/91afa2e02a50ef02
HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
Cookie: __cf_bm=vDHQje3WaDMIy8v6hQTWVkgn6h3P.pIZMRogn6tmvwk-1741073090-1.0.1.1-
p2k0.h7_89_xAFMq26gTrhC6tqHzf.i5jLRTg6UMs6TwUcW8GFriaTsrcitTP7jCj89TgK6xWVF7CBPOjaKk4U_PActv3oE_jI8s_DCuaug
Origin: https://www.atherenergy.com
Content-Type: text/plain;charset=UTF-8
Sec-CH-UA: "Google Chrome";v="133", "Not=A?Brand";v="8", "Chromium";v="133"
Sec-CH-UA-Platform: "Linux"
Sec-CH-UA-Mobile: ?0
Content-Length: 15921

WHo5eB+meVoeEw8+C+ZP15BGPuMPfyfggBm+dkPsQGnQOoPxsiv8QV+KPECoXcHHPu-gPFPgGgo+Pbg+q8h5-VHY045sQlHMu3KZwXS5qleJMT+3ks-
fPeooRfxBYcPDXcOUYPU5wxPBJoPf5BB5lE5fP+QP1VAP+TYPLjmuXHi+u-
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:24:51 GMT
Content-Type: text/plain; charset=UTF-8
Content-Length: 0
Set-Cookie: cf_clearance=; Path=/; Expires=Thu, 01-Jan-70 00:00:00 GMT; Domain=atherenergy.com; HttpOnly; Secure; SameSite=None
Set-Cookie: cf_clearance=o4fulW2VqtADEbUAS3CdWYXX2xnd5wo804.cQTygE94-1741073091-1.2.1.1-
orswPdvPQ1579J6i3TV2MRAj60NIlcDUTFneX5BT1gOj8lx0i8CKR8n4cmLJkEgJE48FAv9_xDOs9MokcUJafEJjfr.emmjgTSUrQa0eNkA7rhWqnHtAa8qKKEXWkd
5_yCjlunfMpGp4glNUeX9uCwfLEH5TvhlNxn102qvHAe1B1KrV1eL8nnSp32XXP2g211dbY1iO.dLm5jUMi8wsglpWd5BNVnTHLzR4lN2HOAwHDc3hElFuGGcdBo
N.uPXz8dDWGwA8UmOwb.NKxRiZWVepoFoovGNwCejh6FQtlcths18ax8HYhl1zPe7CpmLMJrrgOP0gzzAiSMccz8.nV0Bhaj9QzjOk_HyU.Q0Fp5fcTHy.E_rhqbfO
ZxBIC_teLQraT7nwTSA.1k5wxCZ9.XzkQfBo8kw3f7KBQfALNtE; Path=/; Expires=Wed, 04-Mar-26 07:24:51 GMT; Domain=atherenergy.com; HttpOnly; Secure;
SameSite=None; Partitioned
Server: cloudflare
Cf-Ray: 91afa2e43f64ef02-AMS
Alt-Svc: h3=":443"; ma=86400
```

6.2. https://www.atherenergy.com/robots.txt

Previous

Summary

Severity:	**Information**
Confidence:	**Certain**
Host:	**https://www.atherenergy.com**
Path:	**/robots.txt**

Request 1

```
GET /robots.txt HTTP/2
Host: www.atherenergy.com
Accept-Encoding: gzip, deflate, br
Accept: */*
Accept-Language: en-US;q=0.9,en;q=0.8
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
Connection: close
Cache-Control: max-age=0
```

Response 1

```
HTTP/2 200 OK
Date: Tue, 04 Mar 2025 07:24:54 GMT
Content-Type: text/plain; charset=UTF-8
Cache-Control: public, max-age=10800
Last-Modified: Fri, 14 Feb 2025 16:03:45 GMT
Etag: W/"48-1950533a2e8"
Vary: Accept-Encoding
Strict-Transport-Security: max-age=31536000; includeSubDomains
Cf-Cache-Status: MISS
Expires: Tue, 04 Mar 2025 10:24:54 GMT
Set-Cookie: __cf_bm=r559CTcjrzuzHAOjnffU1MpF625Gsqvhv6YTYFiO7Z8-1741073094-1.0.1.1-
HEW7pzEv2nfkx1ThN1BoHGs1Xx.ofcd5Qj4V1sg9HU9C5j4Q6SN1sZMgY2fV4rNqBwWn377yPjg2Y9Kkaw6y6aSBDFzMGhxcVsEfrZivhB4; path=/; expires=Tue,
04-Mar-25 07:54:54 GMT; domain=.atherenergy.com; HttpOnly; Secure; SameSite=None
Server: cloudflare
Cf-Ray: 91afa2f8ed74ef02-AMS
Alt-Svc: h3=":443"; ma=86400

User-Agent: *
Allow: /
```

Report generated by Burp Suite web vulnerability scanner v2025.1.1, at Tue Mar 04 13:46:34 IST 2025.